Hybrid Retrieval and Cross-Encoder Reranking for ISO/IEC 27001:2022 SoA Control Mapping

Muhammad Hilmi Dzaki Wismadi
Department of Electrical and Information Engineering
Universitas Gadjah Mada
Yogyakarta, Indonesia
muhammadhilmidzakiwismadi@mail.ugm.ac.id

Ir. Sujoko Sumaryono, M.T.
Department of Electrical and Information Engineering
Universitas Gadjah Mada
Yogyakarta, Indonesia
sujoko@ugm.ac.id

***Abstract*—Compliance auditing against ISO/IEC 27001:2022 requires mapping organizational policy documents to specific Annex A controls, a process that is time-consuming and error-prone when performed manually. This paper evaluates retrieval strategies within a Retrieval-Augmented Generation (RAG) framework to support automated Statement of Applicability (SoA) control mapping. Three design axes are investigated: the weight composition between dense and sparse retrieval, the candidate pool size for cross-encoder reranking, and the score fusion weight between hybrid retrieval and cross-encoder scores. Experiments are conducted using 77 queries derived from Directorate of Information Technology (DTI) Universitas Gadjah Mada policy documents against a knowledge base of 93 ISO/IEC 27001:2022 Annex A controls. Non-parametric statistical testing confirms that all three design axes significantly affect retrieval performance. A per-query analysis further reveals that hybrid retrieval and cross-encoder reranking exhibit complementary strengths depending on query characteristics, providing a basis for the optimal score fusion configuration identified in this study.**

***Index Terms*—ISO/IEC 27001, Statement of Applicability, hybrid retrieval, cross-encoder reranking, retrieval-augmented generation, information security audit**

I. Introduction

The accelerating pace of digital transformation has expanded organizational attack surfaces, making information security management increasingly complex. The Check Point Global Cyber Attack Report 2026 indicates that the education sector experienced an average of 4,749 cyber attacks per organization per week, a 7% year-over-year increase, with the Asia-Pacific region averaging 3,040 attacks per week [1]. In response, organizations adopt ISO/IEC 27001, which provides a risk-based Information Security Management System (ISMS) framework [2], [3]. The 2022 revision consolidated Annex A from 114 to 93 controls across four categories: organizational, people, physical, and technological [2].

However, ISO 27001 compliance auditing remains operationally burdensome. Certification can span 6–12 months with significant cost [4], primarily due to analytical activities such as control-to-document mapping, evidence evaluation, and Statement of Applicability (SoA) preparation. The SoA, which links risk assessment outcomes to implemented controls, is particularly critical: auditors must verify that each Annex A control is consistently evaluated with supporting evidence, a process prone to inconsistency and scalability limitations when performed manually [5].

Retrieval-Augmented Generation (RAG) architectures offer a promising approach for document-grounded analysis by combining natural language understanding with external knowledge retrieval. Prior work demonstrates that RAG performance is heavily influenced by retrieval quality, including query representation, document search, and relevance ranking [6]–[9]. In audit and compliance domains, Liu et al. [7] combined BM25 and dense retrieval with weighted Reciprocal Rank Fusion for audit-to-regulation mapping. Gupta et al. [6] applied DPR with cross-encoder reranking for GDPR/CCPA compliance checking. Ravishankar and Varalakshmi [10] integrated hybrid retrieval, reranking, and score fusion for financial document QA. Rustamov et al. [11] compared sparse, dense, and reranking strategies for tax law QA. Elkiran and Rasheed [12] provided empirical evidence that retriever selection, similarity function, and reranker choice significantly affect RAG performance.

Despite these advances, no prior work has systematically compared hybrid retrieval weight compositions, candidate pool sizes for reranking, and score fusion strategies specifically for ISO/IEC 27001:2022 SoA control mapping. This paper addresses this gap with the following contributions:

1) A multi-axis evaluation of dense/sparse weight compositions in hybrid retrieval for ISO 27001 control mapping.
2) A candidate pool size ablation for cross-encoder reranking, analyzing both accuracy and latency trade-offs.
3) A score fusion analysis between hybrid retrieval and cross-encoder scores, validated by non-parametric statistical testing (Friedman test).
4) A per-query characteristic analysis revealing the complementary nature of hybrid retrieval and cross-encoder reranking.

II. Related Work

A. RAG for Audit and Compliance

Liu et al. [7] modeled audit-finding-to-regulation mapping using multi-path retrieval combining BM25 and BGE-based dense retrieval, fused via weighted Reciprocal Rank Fusion, achieving Recall@5 of 0.5210 and MRR@5 of 0.3869. Gupta et al. [6] developed a RAG system for GDPR/CCPA compliance checking using DPR followed by cross-encoder reranking, reaching Recall@10 and Precision@10 of 98.2% at the cost of 3.4 s additional latency per query. Ravishankar and Varalakshmi [10] explored query expansion, dense retrieval, and cross-encoder reranking with score fusion for financial document QA, achieving MAP of 0.861 and Recall@10 of 0.923, significantly outperforming DPR-only baselines. Rustamov et al. [11] demonstrated that hybrid retrieval (BM25/SPLADE + dense) improved Recall@100 from 0.49 to 0.60 and cross-encoder reranking improved NDCG from 0.39 to 0.44 on tax law QA. Elkiran and Rasheed [12] provided comprehensive empirical evaluation of RAG pipeline components, showing that retriever and similarity function selection have the most significant impact ($p < 10^{-9}$) on system performance.

B. Hybrid Retrieval and Reranking

Hybrid retrieval combines sparse methods (e.g., BM25) that capture exact lexical matches with dense methods (e.g., neural embeddings) that capture semantic similarity. This combination is particularly beneficial in regulatory domains where both explicit terminology matching and contextual understanding are required. Cross-encoder reranking further refines candidate rankings by jointly encoding query–document pairs, achieving higher precision at the cost of increased latency. The interplay between hybrid retrieval weights, candidate pool sizes, and score fusion proportions remains under-characterized in the ISO 27001 compliance domain.

III. Methodology

A. Knowledge Base Construction

The knowledge base is constructed from the ISO/IEC 27001:2022 standard, covering Annex A controls A.5 (Organizational Controls), A.6 (People Controls), A.7 (Physical Controls), and A.8 (Technological Controls), totaling 93 controls. Each control is stored as a structured JSON entity containing attributes: `control_id`, `title`, `objective`, `description`, `implementation_guidance`, bilingual keywords (`keywords_en/id`), bilingual audit indicators (`audit_indicators_en/id`), bilingual related assets (`related_assets_en/id`), and bilingual security principles (`security_principles_en/id`). This enriched representation supports both lexical and semantic retrieval pathways.

B. Query and Ground Truth Construction

Seventy-seven queries were derived from four DTI UGM policy documents through manual reading to identify statements, policies, and organizational conditions relevant to ISO/IEC 27001:2022 Annex A controls:

- Rector Decree No. 357/2026 on Domain Management Guidelines (93 control references, dominated by A.5 and A.8).
- Rector Regulation No. 13/2025 on IT Governance at UGM (81 references, the only document referencing A.6 People Controls).
- Rector Decree No. 1198/2025 on Password Standards and SIMASTER Finance Security (39 references, dominated by A.8 Technological Controls).
- Rector Circular No. 3779/2025 on Software Usage in UGM (18 references, dominated by A.5.32 Intellectual Property Rights).

Each query is assigned three ground truth controls, yielding 231 total control references. The distribution is skewed toward A.5 (58.9%) and A.8 (38.1%), with A.6 (2.2%) and A.7 (0.9%) having limited representation due to the nature of the available policy documents.

C. Hybrid Retrieval

The hybrid retrieval component integrates sparse and dense retrieval. BM25 serves as the sparse component, chosen for its probabilistic term matching well-suited to ISO 27001's explicit terminology. The dense component uses paraphrase-multilingual-MiniLM-L12-v2 (384 dimensions, 50+ languages including Indonesian) for semantic similarity. Both score streams are min-max normalized to $[0, 1]$ and combined via weighted sum:

$$\text{hybrid\_score} = \alpha_d \cdot s_{\text{dense}}^{\text{norm}} + (1 - \alpha_d) \cdot s_{\text{sparse}}^{\text{norm}} \tag{1}$$

where $\alpha_d \in \{0.00, 0.25, 0.50, 0.75, 1.00\}$ controls the dense-to-sparse ratio. The top-k documents form the candidate pool for reranking.

Fig. 1. Hybrid retrieval architecture combining BM25 sparse retrieval with dense embedding retrieval via weighted score fusion.

D. Cross-Encoder Reranking and Score Fusion

The candidate pool from hybrid retrieval is re-evaluated by BAAI/bge-reranker-v2-m3, a multilingual cross-encoder. The final score fuses hybrid and cross-encoder scores:

$$\text{final\_score} = \alpha_r \cdot s_{\text{hybrid}}^{\text{norm}} + (1 - \alpha_r) \cdot s_{\text{CE}}^{\text{norm}} \tag{2}$$

where $\alpha_r \in \{0.00, 0.25, 0.50, 0.75, 1.00\}$ controls the hybrid-to-CE ratio. Setting $\alpha_r = 1.0$ reverts to pure hybrid retrieval; $\alpha_r = 0.0$ uses only cross-encoder scores. Both α_d and α_r follow the same discrete range and the complementary weights always sum to 1.

Fig. 2. Cross-encoder reranking pipeline: hybrid retrieval produces a candidate pool, which the cross-encoder re-evaluates before score fusion.

E. Experimental Design

Three sequential experimental scenarios are conducted, where each subsequent scenario uses the optimal configuration from the previous one:

Scenario 1: Dense/Sparse Weight Composition. Five configurations are tested: $w_{\text{dense}} \in \{0.00, 0.25, 0.50, 0.75, 1.00\}$.

Scenario 2: Candidate Pool Size. Four pool sizes are tested: $k \in \{5, 10, 15, 20\}$, using the optimal dense/sparse composition from Scenario 1.

Scenario 3: Score Fusion Weight. Five α values are tested: $\alpha \in \{0.00, 0.25, 0.50, 0.75, 1.00\}$, using optimal configurations from Scenarios 1 and 2.

F. Evaluation Metrics and Statistical Testing

Four metrics are used: Hit@3 and Recall@3 for coverage, and Average Reciprocal Rank (ARR) and NDCG@3 for ranking quality. The Friedman test [13] with $\alpha_{\text{sig}} = 0.05$ is applied to assess statistical significance across configurations, using 77 queries as the blocking factor for repeated-measures comparison.

IV. Results and Discussion

A. Scenario 1: Dense/Sparse Weight Composition

TABLE I
RETRIEVAL PERFORMANCE ACROSS DENSE/SPARSE WEIGHT COMPOSITIONS

Configuration	Hit@3	Recall@3	ARR	NDCG@3
Dense 0.00 : Sparse 1.00	0.961	0.485	0.335	0.525
Dense 0.25 : Sparse 0.75	0.948	0.506	0.350	0.549
Dense 0.50 : Sparse 0.50	**0.935**	**0.537**	**0.364**	**0.575**
Dense 0.75 : Sparse 0.25	0.831	0.468	0.327	0.511
Dense 1.00 : Sparse 0.00	0.649	0.307	0.215	0.336

Table I shows that the balanced configuration ($w_{\text{dense}} = 0.50$) achieves the best performance on three of four metrics: Recall@3 = 0.537, ARR = 0.364, and NDCG@3 = 0.575. Pure sparse retrieval ($w_{\text{dense}} = 0.00$) yields the highest Hit@3 = 0.961 but lower rank-sensitive metrics. Pure dense retrieval performs substantially worse across all metrics. These results confirm that ISO 27001 control mapping requires both semantic matching (dense) to capture contextual meaning and lexical matching (sparse) to recognize domain-specific terminology.

TABLE II
FRIEDMAN TEST RESULTS FOR DENSE/SPARSE WEIGHT COMPOSITIONS

Metric	χ^2	p-value
Hit Rate	52.205	< 0.000001
Recall	53.542	< 0.000001
NDCG	46.395	< 0.000001
ARR	39.847	< 0.000001

The Friedman test (Table II) confirms that differences across configurations are highly significant ($p < 0.001$) for all metrics, rejecting the null hypothesis.

B. Scenario 2: Candidate Pool Size

TABLE III
RETRIEVAL PERFORMANCE AND LATENCY ACROSS CANDIDATE POOL SIZES

Pool	Hit@3	Recall@3	ARR	NDCG@3
5	**0.857**	**0.468**	**0.302**	**0.485**
10	0.753	0.424	0.285	0.451
15	0.701	0.394	0.264	0.418
20	0.688	0.377	0.258	0.405

Table III reveals a consistent monotonic decline: pool size 5 achieves the highest scores across all metrics with the lowest total latency (9.01 s). Increasing the pool to 20 degrades Hit@3 by 0.169, Recall@3 by 0.091, and nearly triples latency to

25.61 s. This counter-intuitive result indicates that including less relevant candidates introduces noise that degrades cross-encoder ranking quality in the ISO 27001 domain.

The Friedman test (Table IV) confirms significance ($p < 0.003$) across all metrics.

TABLE IV
FRIEDMAN TEST RESULTS FOR CANDIDATE POOL SIZES

Metric	χ^2	p-value
Hit Rate	16.760	0.000792
Recall	14.095	0.002779
NDCG	25.776	0.000011
ARR	27.091	0.000006

C. Scenario 3: Score Fusion Weight

TABLE V
RETRIEVAL PERFORMANCE ACROSS SCORE FUSION COMPOSITIONS (HYBRID:CE)

Config (Hybrid:CE)	Hit@3	Recall@3	ARR	NDCG@3
1.00 : 0.00	0.935	0.537	0.364	0.575
0.75 : 0.25	**0.935**	**0.541**	**0.367**	**0.579**
0.50 : 0.50	0.896	0.528	0.346	0.553
0.25 : 0.75	0.883	0.502	0.323	0.519
0.00 : 1.00	0.855	0.469	0.302	0.485

Table V shows that the hybrid-dominant configuration ($\alpha = 0.75$) achieves the best overall performance (Recall@3 = 0.541, NDCG@3 = 0.579), marginally surpassing pure hybrid retrieval. Pure cross-encoder ($\alpha = 0.00$) yields the lowest performance, indicating that hybrid retrieval scores carry more relevant signals for ISO 27001 control mapping. This consistent pattern, where performance decreases as CE weight increases, confirms that hybrid retrieval should dominate.

TABLE VI
FRIEDMAN TEST RESULTS FOR SCORE FUSION COMPOSITIONS

Metric	χ^2	p-value
Hit Rate	5.200	0.074
Recall	6.300	**0.043**
NDCG	12.786	**0.002**
ARR	13.421	**0.001**

Three of four metrics show significant differences (Table VI). The non-significance of Hit Rate ($p = 0.074$) is expected given the uniformly high Hit@3 values (0.855–0.935), while rank-sensitive metrics (NDCG, ARR) confirm that score fusion composition meaningfully affects ranking quality.

D. Per-Query Analysis: Hybrid vs. Cross-Encoder

A direct per-query comparison between pure hybrid and pure cross-encoder using NDCG@3 (Table VII) reveals complementary strengths:

TABLE VII
QUERY DISTRIBUTION BY WINNING COMPONENT (NDCG@3)

Category	Queries	Proportion
Hybrid retrieval superior	36	46.8%
Tied performance	26	33.8%
Cross-encoder superior	15	19.5%
Total	**77**	**100%**

Cross-encoder superiority (15 queries) occurs in three patterns: (i) key phrases lack direct lexical matches with ISO control terminology (e.g., “non-legal software” vs. “licensed software” in A.5.32); (ii) cross-encoder discovers additional ground truth controls that hybrid retrieval misses due to cross-lingual terminology gaps (e.g., “Authentication” vs. “autentikasi”); and (iii) cross-encoder improves ranking on contextual/procedural queries describing organizational frameworks without explicit ISO terminology (e.g., IT governance frameworks mapping to A.5.1, A.5.4).

Hybrid retrieval superiority (36 queries) occurs when: (i) cross-encoder fails completely while hybrid retrieval succeeds via combined lexical and semantic signals (8 queries); (ii) short queries with specific keywords enable precise BM25 matching (6 queries); and (iii) queries mentioning technical assets or infrastructure (22 queries) benefit from BM25’s partial term matching and dense embeddings’ semantic generalization.

These findings justify assigning a small weight (25%) to the cross-encoder in the optimal score fusion: it provides marginal yet consistent improvements on contextually demanding queries without degrading the strong baseline established by hybrid retrieval.

V. CONCLUSION

This paper systematically evaluates retrieval strategies for RAG-based ISO/IEC 27001:2022 SoA control mapping across three design axes. The key findings are:

1) **Balanced hybrid retrieval is optimal.** The dense = 0.50, sparse = 0.50 composition achieves the best Recall@3 (0.537) and NDCG@3 (0.575), confirming that ISO 27001 control mapping requires both semantic and lexical matching. All differences are statistically significant ($p < 0.001$, Friedman test).
2) **Smaller candidate pools outperform larger ones.** A pool size of 5 yields the highest accuracy and lowest latency (9.01 s), with monotonic degradation as pool size increases. Larger pools introduce noise that degrades cross-encoder ranking ($p < 0.003$).
3) **Hybrid-dominant score fusion is preferred.** Hybrid:CE = 0.75:0.25 achieves the best overall performance (Recall@3 = 0.541, NDCG@3 = 0.579). Cross-encoder contribution is complementary rather than dominant: hybrid retrieval excels on terminology-driven queries (46.8%), while cross-encoders benefit contextual queries (19.5%).

Future work includes: validation on diverse organizational documents, evaluation of smaller pool sizes ($k < 5$), end-to-end RAG generation evaluation, finer-grained weight search, post-hoc pairwise statistical tests, and adaptive retrieval strategies that dynamically adjust fusion weights based on query characteristics.

Acknowledgment

The authors thank the Directorate of Information Technology, Universitas Gadjah Mada, for providing the policy documents used in this study.

References

[1] Check Point Research, "Check Point Global Cyber Attack Report 2026," https://research.checkpoint.com/, 2026.

[2] A. Calder, *ISO 27001:2022 - A Pocket Guide*, 3rd ed. IT Governance Publishing, 2023.

[3] ISO/IEC, *ISO/IEC 27001:2022 – Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements*, International Organization for Standardization Std., 2022.

[4] B. Marques *et al.*, "Automating ISO 27001 compliance: A systematic literature review," *Computers & Security*, vol. 144, 2024.

[5] CSAM Research Group, "Challenges in automating ISO 27001 compliance analysis: A practitioner study," in *Proceedings of the International Workshop on Security Compliance and Audit*, 2024.

[6] S. Gupta *et al.*, "RAG-based compliance checking for GDPR and CCPA regulations," in *Proceedings of the AAAI Conference on Artificial Intelligence*, 2025.

[7] A. Liu *et al.*, "Multi-path retrieval for audit finding mapping to regulatory basis," in *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing*, 2025.

[8] Z. Wang *et al.*, "AuditGPT: Automating audit evidence analysis with large language models," in *Proceedings of the 2025 International Conference on Software Engineering*, 2025.

[9] Y. Chen *et al.*, "ReguQuery: Query optimization for regulatory document retrieval," in *Proceedings of the 2025 ACM SIGIR Conference*, 2025.

[10] B. Ravishankar and P. Varalakshmi, "Hybrid retrieval with cross-encoder reranking and score fusion for financial document QA," *Information Processing & Management*, vol. 62, 2025.

[11] A. Rustamov *et al.*, "Hybrid retrieval and cross-encoder reranking for tax law question answering," *Expert Systems with Applications*, vol. 238, 2025.

[12] M. Elkiran and H. Rasheed, "An empirical evaluation of RAG pipeline components: Retrievers, similarity functions, and rerankers," *Information Retrieval Journal*, 2026.

[13] D. G. Pereira, W. Afonso, and A. M. Lombardi, "Overview of friedman's test and post-hoc analysis," *Communications in Statistics – Simulation and Computation*, vol. 44, no. 10, pp. 2598–2619, 2015.